

ORYALIS

Audit Clients, Contacts, Rendez-vous Pipeline & Prochaine action

Audit technique, fonctionnel et UX — préalable à la refonte UI

MÉTHODE

Audit strictement en lecture seule : aucun fichier modifié, aucun commit, aucune migration exécutée. Preuves sourcées fichier + ligne. Analyse initiale basée sur les migrations SQL et le code du dépôt, puis complétée par une vérification live du schéma Supabase (information_schema, pg_catalog) via des requêtes SQL en lecture seule exécutées directement par l'utilisateur.

Périmètre : app/(app)/clients, appointments, followups, network, orders, catalog, dashboard — features/ et shared/ associés

Branche main · commit f10a56a · 26-27 juillet 2026 · v2 avec vérification live

A · SYNTHÈSE

Verdict exécutif

MATURITÉ ACTUELLE

Le socle Client / RDV / Pipeline / Prochaine action est plus solide que ne le laisse craindre la dette d'empilement de ~40 scripts migrate*.mjs : un mécanisme DB centralisé (triggers SECURITY DEFINER) calcule next_action_at et pipeline_stage de façon fiable, indépendamment du chemin d'écriture applicatif. La vérification live du schéma (information_schema/pg_catalog) confirme point par point ce qui avait été déduit des migrations.

Deux failles structurelles majeures

- Un second type Appointment obsolète cohabite dans shared/lib/types.ts avec le type réel utilisé par le code actif. La vérification live confirme que native_event_id, appointment_number, appointment_date, themes_discussed, solutions_proposed, recap_sent et next_appointment_date n'existent PAS dans la table appointments réelle — la synchronisation calendrier native (useCalendarSync*) est donc CONFIRMÉE cassée en silence.
- Deux chemins UI pour compléter un rendez-vous produisent des effets métier différents : depuis la fiche RDV, les relances automatiques et la tâche objections se déclenchent ; depuis le dossier client (widget "prochaine action"), rien ne se déclenche.

Autres constats clés

- Un mot de passe PostgreSQL en clair a été trouvé dans migrate4.mjs (CRITIQUE, à faire tourner immédiatement).
- Le pipeline commercial peut être écrasé silencieusement par une édition manuelle concurrente à la synchronisation automatique depuis un RDV ou une relance.
- Aucune contrainte CHECK n'existe sur appointments en live (confirmé) : rien n'empêche un rendez-vous avec end_at < start_at.
- L'i18n est globalement rigoureuse, à l'exception du module "Console owner" récent : non traduit, avec fr-FR et € en dur.

Possibilité de refonte UI

La refonte visuelle peut démarrer sans risque sur les écrans de lecture pure (dashboard, listes, agenda en consultation). Elle doit être précédée d'un correctif P0 (secret + réparation ou retrait de la sync calendrier + unification du chemin de complétion RDV) avant de toucher la fiche RDV et le pipeline.

B · COUVERTURE

Périmètre réellement audité

Lu intégralement

shared/lib/types.ts · features/appointments/* (service, types, sync natif/Google) · features/clients/* (service, next-action, export/import, quota) · features/automations/automationService.ts · features/followups/* · features/dashboard/useDashboard.ts · features/network/* · features/orders/* · features/goals/* · features/demo/* · shared/i18n/* · shared/theme/* · shared/components/ui/* · la quasi-totalité de app/(app)/clients/**, app/(app)/appointments/**, app/(app)/network/**, app/(app)/orders/index.tsx, app/(app)/catalog/**, app/(app)/export.tsx, app/(app)/import.tsx, app/(app)/goals.tsx, app/(app)/index.tsx · tous les supabase/migrations/*.sql · une large sélection de migrate4.mjs à migrate40.mjs et migrate_agenda*.mjs.

Non vérifié directement / hors périmètre de cette passe

- Détail composant par composant de Button.tsx / Card.tsx (survolés, pas lus intégralement).
- app/(app)/clients/[id]/notes.tsx, orders.tsx, recommendations.tsx : lus partiellement, pas ligne à ligne.
- features/interactions/* : lu partiellement.
- Tous les sites d'appel de trackProductEvent hors productAnalytics.ts lui-même.
- Contenu exact des colonnes ajoutées par migrate9/10/12.mjs sur catalog_products.
- Origine exacte de plusieurs colonnes profiles/clients dont les scripts créateurs (migrate.mjs, migrate2.mjs, migrate3.mjs) ont été supprimés du dépôt après usage — cette partie de l'historique du schéma n'est plus reconstituable depuis ce dépôt, même avec l'accès live (elle précède l'état actuel).

ACCÈS DB LIVE

Une vérification live complémentaire a été réalisée après la rédaction du rapport initial : l'utilisateur a exécuté, dans Supabase SQL Editor, une série de requêtes en lecture seule (information_schema.columns, pg_constraint, pg_enum, pg_policies, information_schema.triggers, pg_proc) et m'a communiqué les résultats. Voir la section C2 pour le détail des confirmations. Les points non listés en C2 restent au statut "conforme aux fichiers de migration, non vérifié en production".

C · VÉRIFICATION NON DESTRUCTIVE

État Git

Élément	Valeur
Branche	main
Commit HEAD (avant et après)	f10a56a7124852f3405524b9405cdbc421737a5f
État initial	32 fichiers modifiés préexistants (non liés à l'audit) + 5 fichiers non suivis (docs/*.pdf, generate-*.mjs)
État final	Stricte­ment iden­tique — même liste de fichiers, même diff --stat, HEAD inchangé

CONFIRMATION EXPLICITE

Aucun fichier n'a été modifié, créé, supprimé, renommé ou committé pendant cet audit ni pendant la vérification live complémentaire (requêtes SQL exécutées par l'utilisateur lui-même, aucun accès DB direct depuis cette session). Les 32 fichiers marqués "M" par git status correspondent à un travail en cours de l'utilisateur, antérieur à cette session.

C2 · COMPLÉMENT POST-RAPPORT

Vérifications live du schéma Supabase

L'utilisateur a exécuté, dans Supabase SQL Editor, une série de requêtes en lecture seule sur `information_schema / pg_catalog` et m'a communiqué les résultats en aparté. Ce complément met à jour la classification de plusieurs constats du rapport initial, de PROBABLE/NON VÉRIFIÉ vers CONFIRMÉ, et documente deux découvertes nouvelles.

Constats reclassés en CONFIRMÉ

Constat	Avant	Après vérification live
<code>duration_minutes</code> est une colonne générée (GENERATED ALWAYS AS ... STORED)	PROBABLE	CONFIRMÉ
<code>native_event_id</code> , <code>appointment_number</code> , <code>appointment_date</code> , <code>themes_discussed</code> , <code>solutions_proposed</code> , <code>recap_sent</code> , <code>next_appointment_date</code> absents de <code>appointments</code>	PROBABLE	CONFIRMÉ — sync calendrier natif cassée en production
Aucune contrainte CHECK sur <code>appointments</code> (pas de <code>end_at > start_at</code>)	PROBABLE	CONFIRMÉ
<code>clients_pipeline_stage_check</code> : exactement 8 valeurs, identiques au TS <code>PIPELINE_STAGES</code>	PROBABLE (déduit des migrations)	CONFIRMÉ
<code>pipeline_stage_enum</code> (<code>appointment_business_context</code>) : exactement 10 valeurs, dont <code>proposal_sent</code> et <code>inactive</code> orphelins	PROBABLE (déduit de <code>migrate_agenda.mjs</code>)	CONFIRMÉ
<code>clients_status_check</code> : exactement 9 valeurs, identiques au TS <code>ClientStatus</code>	PROBABLE	CONFIRMÉ
RLS activé sur les 30 tables du schéma public, aucune "forcée"	NON VÉRIFIÉ	CONFIRMÉ
Doublons de politiques RLS ALL sur <code>followups</code> , <code>notes</code> , <code>recommendations</code> ; clients déjà nettoyé (1 seule policy)	PROBABLE / partiel	CONFIRMÉ et précisé
4 tables (<code>admin_audit_log</code> , <code>pilot_participants</code> , <code>security_login_events</code> , <code>user_roles</code>) : RLS activé mais aucune policy !' accès verrouillé par défaut, uniquement via fonctions <code>SECURITY DEFINER</code>	Déduit des migrations <code>owner_security.sql</code>	CONFIRMÉ
Trigger <code>handle_new_user()</code> AFTER INSERT ON <code>auth.users</code>	Déduit de <code>20260602_init.sql</code>	CONFIRMÉ
<code>handle_new_user()</code> a bien un <code>search_path</code> fixé ('public')	Le rapport initial supposait, par lecture du fichier de migration, qu'aucun <code>search_path</code> n'était fixé	INFIRMÉ — le <code>search_path</code> est bien fixé en live ; ce risque est retiré du rapport

Découvertes
nouvelles (visibles
uniquement via
l'introspection live)

- Table google_calendar_tokens (tokens OAuth Google Calendar), RLS ALL auth.uid()=user_id — non évaluée dans le volet RGPD/sécurité du rapport initial ; à ajouter au périmètre de revue des données sensibles.
- Un second système d'analytics existe côté base (fonctions analytics_client_created, analytics_contact_event, analytics_onboarding, analytics_profile_created, analytics_subscription — toutes SECURITY DEFINER, search_path fixé), alimentant product_events en parallèle du système JS déjà audité (productAnalytics.ts). Non documenté dans le rapport initial.
- appointment_tasks repose sur un système de tâches généralisé (task_type_enum : follow_up, send_catalog, send_price_list, send_sample, invite_to_webinar, invite_to_training, send_payment_link, customer_checkin, team_followup, ask_referral, other — 11 valeurs ; plus task_status_enum et task_priority_enum) — plus large que la seule "tâche objections" décrite dans les sections I/J/M du rapport initial.
- Le commentaire live de enforce_free_contact_quota() confirme explicitement que "advisor"/"leader" sont des "legacy paid plan names kept valid during the pricing transition" — l'équipe a donc déjà connaissance du chevauchement de vocabulaire relevé en sections G et Q.

LIMITE DE CE COMPLÉMENT

Toutes les vérifications live n'ont pas été demandées (ex. contenu détaillé de has_advisor_access, is_app_owner, fonctions owner_*, sync_client_pipeline_from_appointment/followup). Leur comportement reste au statut "conforme aux fichiers de migration lus", non re-vérifié en production, mais aucune contradiction n'a été observée sur les points effectivement vérifiés.

D · FLUX DE DONNÉES

Architecture réelle

Flux nominal

UI (écran) → hook (use[Resource].ts) → service ([resource]Service.ts) → Supabase (.select/.insert/.update) → triggers PostgreSQL SECURITY DEFINER (recalcul next_action_*, pipeline_stage) → automatisations JS fire-and-forget (automationService.ts, relances conditionnelles) → affichage (dashboard, fiche client, agenda).

Contournements confirmés du flux

- app/(app)/catalog/index.tsx:283-291 — requête Supabase directe (supabase.from('clients')...) dans le composant, hors clientService.
- nextActionService.completeNextAction() — UPDATE appointments SET status='completed' direct, contournant appointmentService.updateAppointment() et donc toute la chaîne d'automatisation post-complétion.
- features/orders/orderService.ts — ne filtre pas explicitement user_id dans fetchOrders (repose uniquement sur RLS), contrairement à tous les autres services.

E · CARTOGRAPHIE

Matrice des routes et écrans

Route	Objectif	Contournement	Doublon principal
clients/index.tsx	Liste + filtres	Non	Score prospect recalculé aussi dans [id]/index.tsx
clients/new.tsx	Création contact	Non	Formulaire quasi identique à edit.tsx (constantes dupliquées)
clients/[id]/edit.tsx	Édition contact	Non	Duplication quasi totale de new.tsx
clients/[id]/index.tsx	Fiche 360°	Non	Score prospect dupliqué
clients/[id]/team.tsx	Downline MLM (lecture)	Non	Duplique l'onglet "team" déjà présent dans [id]/index.tsx
clients/archived.tsx	Liste archivés	select(*) — champs sensibles inclus, non affichés	—
settings-labels.tsx / settings-crm.tsx	Libellés de statut	Non	Section labels dupliquée à ~95% entre les deux écrans
appointments/index.tsx, new.tsx, [id]/index.tsx	Agenda / création / fiche RDV	Non	—
followups/index.tsx, clients/[id]/followups.tsx	Relances	Non	—
network/index.tsx, network/upline.tsx	Réseau MLM	Non	Filtrage arbre en JS non paginé
orders/index.tsx	Commandes + CA mensuel	Non	Calcul CA dupliqué 3× avec des filtres différents
catalog/index.tsx, protocols.tsx	Catalogue + recommandation	Oui (catalog/index.tsx)	Recherche client dupliquée entre les deux écrans
export.tsx / import.tsx	Export / Import	Non	—
index.tsx (dashboard)	KPIs, agenda, pipeline, réseau	Non	Sections mortes ({false && ...}), calculs dupliqués avec useDailyActions
goals.tsx	Objectifs	Non	Calcul CA "revenue" divergent de useMonthlyRevenue

Impact web/mobile : toutes les routes sont web-first (Expo Router file-based, mêmes composants sur mobile). Aucune

divergence de
données affichées
entre plateformes
trouvée pour les
données sensibles
(section O).

F · QUI ÉCRIT QUOI

Matrice des sources de vérité

Information	Source de vérité effective	Ambiguïté / risque
Relation (contact_role)	clients.contact_role	Chevauche status (prospect, team_member, inactive) et le plan d'abonnement (advisor, leader)
Statut (status)	clients.status	9 valeurs TS/CHECK alignées (confirmé live), mais team_member et lost absents des formulaires UI
Pipeline (pipeline_stage)	Non unique — 4 écrivains concurrents + 2 triggers DB	Aucune protection anti-race ; écrasement silencieux possible
Température (prospect_temperature)	appointment_business_context	Enum confirmé live (4 valeurs), aucun CHECK supplémentaire nécessaire
Intention (commercial_intent)	appointment_business_context	Enum confirmé live (7 valeurs) — déclenche relances J+2/ J+3, cohérent
Dernière activité (last_interaction_at)	Trigger refresh_client_activity (clients)	RDV no_show exclu du calcul (angle mort)
Prochaine action (next_action_*)	Trigger refresh_client_activity (clients)	Aucune redondance JS confirmée — fiable
Notes RDV / récap	Dispersé (appointment_business_context, notes)	Pas de pipeline "récap partageable" branché (clés i18n orphelines)
Tâches post-RDV	appointment_tasks — système de tâches généralisé (11 types, confirmé live)	Doublons possibles sur double-clic "Completed" pour le type objections
Relances (followups)	Applicatif, contournable par insert direct	Restriction plan/module 100% applicative, pas de RLS
Rendez-vous	appointments (appointmentTypes.ts)	Deux types Appointment concurrents (voir section I)
Calendrier externe	Aucune source unique	3 mécanismes concurrents (natif confirmé cassé, Google fonctionnel, colonnes mortes) + google_calendar_tokens non audité
Rang MLM	Dispersé (contact_role, AlertType.leader_emerging)	"leader" = rôle contact ET plan d'abonnement praticien (confirmé "legacy" par commentaire live)
Fidélité	Dispersé (status=vip, loyalty_notes, doterra_id, next_lrp_date)	VIP et fidélité sont deux notions non reliées, peuvent diverger

G · CLASSÉES PAR SÉVÉRITÉ

Incohérences confirmées

Sévérité	Constat	Preuve et impact
CRITIQUE	Mot de passe PostgreSQL en clair	migrate4.mjs:4-6 — seul script sur ~40 à ne pas utiliser process.env.SUPABASE_DB_PASSWORD. Valeur masquée dans ce document. Recommandation : faire tourner ce mot de passe côté Supabase et envisager une purge d'historique git.
CRITIQUE	Synchronisation calendrier natif cassée en production (CONFIRMÉ live)	calendarSyncService.ts / useCalendarSync.ts / useCalendarForegroundSync.ts interrogent native_event_id, appointment_number, appointment_date, themes_discussed — colonnes dont l'absence de la table appointments a été confirmée par requête live sur information_schema.columns. Erreurs avalées par try/catch + console.error. Hooks appelés à chaque montage de l'app (app/app)/_layout.tsx:233-234).
CRITIQUE	Deux chemins de complétion de RDV aux effets divergents	appointmentService.updateAppointment() déclenche les relances J+2/J+3/J+7 et la tâche objections ; nextActionService.completeNextAction() (clients/[id]/index.tsx:311) fait un UPDATE direct sans déclencher aucune automatisation.
ÉLEVÉE	Export sans masquage des champs médicaux	exportService.ts:7,42 — select(*) exporte medical_treatment, medical_notes, particularities, loyalty_notes en clair (XLSX/JSON), sans consentement granulaire.
ÉLEVÉE	Écrasement possible du pipeline	4 points d'écriture directe (edit.tsx, new.tsx, onboarding, import CSV) concurrents aux triggers de synchro depuis RDV/relances — aucune protection anti-race.
ÉLEVÉE	Doublons de tâche "objections"	appointmentService.ts:198-212 — aucune idempotence ; double-clic sur "Completed" (appointments/[id]/index.tsx:445-467, aucune garde) crée des doublons.
ÉLEVÉE	Gating d'abonnement contournable	automationService.ts:124-140 — restriction par plan/module 100% applicative, aucune RLS équivalente ; un insert direct dans followups contourne le gating.
ÉLEVÉE	Vocabulaire partagé "advisor"/"leader"	Désignent simultanément un rôle de contact MLM et un plan d'abonnement du praticien (subscriptions_plan_check, confirmé live : advisor/leader/entreprise). Le commentaire live de enforce_free_contact_quota() confirme que ce sont des noms de plan "legacy" conservés pendant la transition tarifaire.
MOYENNE	Aucune contrainte CHECK sur appointments (CONFIRMÉ live)	pg_constraint ne retourne aucune ligne de type CHECK pour appointments — aucune protection contre end_at < start_at ; la colonne générée duration_minutes accepterait silencieusement une valeur négative.
MOYENNE	Calcul du CA mensuel dupliqué 3x	useMonthlyRevenue (inclut les commandes personnelles) vs goalService.computeCurrentValues et useOrders.totalAmount (excluent order_type=personal, confirmé par orders_order_type_check : customer/personal) — le KPI dashboard peut diverger du reste de l'app.
MOYENNE	followups.pipeline_stage sans contrainte	Aucun CHECK/enum — une faute de frappe applicative est acceptée silencieusement par le trigger de synchronisation, sans log.
MOYENNE	Incohérences du pipeline en données de démo	Le pipeline d'Emma (distributrice/sponsor) est écrasé à "customer" par le trigger de synchro RDV ; Marie/Thomas/David restent au défaut "new_lead" faute de contexte associé.
MOYENNE	Colonnes quasi-homonymes referrals_count / referral_count	migrate13.mjs:26-27 — toujours écrites en double avec la même valeur (demoService.ts, importService.ts:263) — dette de renommage inachevé.
MOYENNE	Module "Console owner" non traduit	settings-owner.tsx, settings-support-access.tsx — quasiment aucun t(), fr-FR et Alert.alert en dur, développé hors du pipeline i18n habituel.
MOYENNE	Date LRP toujours en fr-FR	MessageModal.tsx:51 — formatDate(client.next_lrp_date, 'fr-FR') indépendamment de la langue active de l'utilisateur.

Sévérité	Constat	Preuve et impact
MOYENNE	Statuts inaccessibles depuis l'UI standard	team_member et lost acceptés par le CHECK DB (confirmé live) mais absents des formulaires new.tsx/edit.tsx — atteignables uniquement via import CSV ou écriture directe.
MOYENNE	Table google_calendar_tokens non auditée (découverte live)	Stocke les tokens OAuth Google Calendar, RLS ALL auth.uid()=user_id — protection de base correcte, mais non évaluée dans le volet sécurité/RGPD initial (durée de vie des tokens, rotation, révocation à vérifier).
FAIBLE	Doublons de policies RLS	followups, notes, recommendations portent chacune 2 policies ALL identiques (confirmé live) ; clients a déjà été nettoyé (1 seule policy). Inoffensif fonctionnellement, à nettoyer pour la lisibilité.
FAIBLE	Tris redondants côté client	orders/index.tsx:45-47 — tri déjà fait côté serveur, refait inutilement en JS.
FAIBLE	Type AppointmentWithClient mort	shared/lib/types.ts:406 — aucun import trouvé ailleurs dans le repo.
FAIBLE	Boucles séquentielles non parallélisées	importService.ts:204-303 et protocols.tsx:169-181 — à mesurer avant d'optimiser (volumes actuels probablement faibles).

H · STATUT PAR CHAMP

Champs et colonnes historiques

Champ / colonne	Statut	Preuve
appointments.appointment_number / appointment_date / themes_discussed / solutions_proposed / recap_sent / next_appointment_date	CONFIRMÉ ABSENT en live (type TS présent, colonne DB absente)	shared/lib/types.ts:322-335 vs requête live information_schema.columns
appointments.native_event_id	Actif dans le code, CONFIRMÉ ABSENT en live (panne silencieuse de la sync native)	add_native_event_id_to_appointments.sql, useCalendarSync.ts, requête live
appointments.external_event_id / external_calendar_id	Mortes côté code, CONFIRMÉES présentes en DB	migrate_agenda.mjs:159-160, aucun import TS, requête live
appointment_business_context.pipeline_stage : proposal_sent / inactive	Obsolètes mais toujours légales dans l'enum Postgres (CONFIRMÉ : enum à 10 valeurs), mappées proprement	20260712_canonical_pipeline.sql:16,19 ; requête live pg_enum
clients.journey_stage	Champ mort / orphelin, explicitement remplacé par pipeline_stage	migrate13.mjs:23, new.tsx:122, edit.tsx:144
clients.referrals_count / referral_count	Candidat à migration future (doublon de renommage inachevé)	migrate13.mjs:26-27
user_status_labels / useStatusLabels.ts	Hook mort (0 import), logique dupliquée dans AppConfigProvider.tsx	grep exhaustif
AppointmentWithClient	Obsolète, non utilisé	shared/lib/types.ts:406-408
appointments.recap_sent + clés i18n recap_cta / send_recap_now	Non vérifié / probablement fonctionnalité retirée	aucun call site trouvé
appointment_tasks.task_type / task_status / task_priority	Système généralisé confirmé live (11 types de tâches), plus large que la seule "tâche objections" décrite initialement	requête live pg_enum : task_type_enum, task_status_enum, task_priority_enum

I · MODÈLE ET SYNCHRONISATION

Audit Appointment

- Deux types concurrents : `shared/lib/types.ts:322-335` (obsolète) vs `features/appointments/appointmentTypes.ts:51-69` (actif, conforme au schéma réel `migrate_agenda2.mjs`, confirmé live).
- Champs obsolètes utilisés uniquement dans le code de synchronisation natif (`calendarSyncService.ts`, `useCalendarSync*.ts`) — leur absence en base de production est désormais CONFIRMÉE (et non plus seulement déduite).
- Trois mécanismes de synchronisation calendrier indépendants : agenda natif (`native_event_id`, confirmé cassé), Google (table séparée `google_calendar_events` — seule réellement fonctionnelle, avec sa propre table de tokens `google_calendar_tokens` découverte en live), et colonnes `external_event_id/external_calendar_id` prévues mais jamais implémentées.
- Tables satellites confirmées par les migrations et par l'introspection live : `appointment_business_context`, `appointment_notes`, `appointment_tasks` (système de tâches généralisé à 11 types), `appointment_attendees`.
- Recommandation : `appointmentTypes.ts` comme source de vérité du modèle métier ; `google_calendar_events` pour la sync Google ; décision produit requise sur le sort de `native_event_id` / sync natif (réparer ou retirer — la panne étant désormais confirmée, ce n'est plus une hypothèse).

J · Audit prochaine action

- Projection DB : `trigger on_contact_event_changed()` + fonction `refresh_client_activity()` (SECURITY DEFINER, `20260712_contact_activity_summary.sql:17-104`), posé sur `appointments/interactions/followups`. Priorité `appointment > interaction > followup`. Seule source de vérité pour `next_action_at`.
- Followups automatiques JS : `automationService.ts`, 5 règles (AUTOMATION_RULES), idempotentes par titre, gating par plan/module purement applicatif.
- Tâches RDV : `appointment_tasks`, système de tâches généralisé (`task_type_enum`, 11 valeurs, confirmé live) créées notamment par `triggerPostCompletionActions` pour le suivi des objections, sans idempotence.
- Un second système de triggers (`analytics_client_created`, `analytics_contact_event`, `analytics_onboarding`, `analytics_profile_created`, `analytics_subscription` — découvert en live) alimente en parallèle `product_events` à des fins d'analytics produit, indépendamment du calcul de `next_action_*`.
- Post-complétion : logique riche (relances conditionnelles + tâche objections + règle J+7) mais non garantie si le RDV est complété via `nextActionService.completeNextAction()` plutôt que via `appointmentService.updateAppointment()`.

K · Audit pipeline

- Valeurs TS (8) = valeurs CHECK clients (8, alignées, CONFIRMÉ live : `new_lead`, `contacted`, `presentation_scheduled`, `presentation_completed`, `follow_up`, `customer`, `distributor`, `lost`). Enum Postgres historique sur `appointment_business_context` (10 valeurs CONFIRMÉES live, avec `proposal_sent/inactive` orphelins). `followups.pipeline_stage` : texte libre, aucune contrainte.
- Triggers `sync_client_pipeline_from_appointment` et `sync_client_pipeline_from_followup` (SECURITY DEFINER) écrasent `clients.pipeline_stage` sans logique de non-régression de rang.
- 4 points d'entrée applicatifs directs (`edit.tsx`, `new.tsx`, `onboarding`, `import CSV`), aucune protection anti-race avec les triggers.

L · Audit activité et chronologie

Sources dispersées sur 6+ tables (`notes`, `appointment_notes`, `interactions`, `followups` terminés, `recommendations`, `orders`). Aucune vue SQL ni RPC d'agrégation existante à ce jour ; chaque écran fiche client fait ses propres requêtes séparées par hook.

OPTION V1 RECOMMANDÉE

Plusieurs requêtes côté service (approche déjà en place, faible risque, pas de nouvelle table) plutôt qu'une vue SQL ou une table dédiée — le volume par client est faible. Une vue matérialisée ne se justifierait qu'après mesure réelle de latence sur un compte à fort historique.

M · SYNTHÈSE PAR ZONE

Audit UX

- Liste Contacts : filtrage/recherche fonctionnels, mais score prospect recalculé en double avec la fiche client ; statuts team_member/lost invisibles dans les filtres UI bien qu'autorisés en DB (confirmé live).
- Création rapide : aucune détection de doublon, aucune validation email/téléphone, formulaire dupliqué à l'identique avec l'édition.
- Fiche Contact : agrège 7+ sources sans couche d'agrégation dédiée ; l'action rapide "Terminer" la prochaine action emprunte un chemin qui ne déclenche pas les mêmes automatisations que la fiche RDV.
- Agenda / fiche RDV : double-clic sur "Completed" sans garde crée des doublons de tâches ; sync calendrier natif CONFIRMÉE cassée (colonnes absentes en production).
- Notes et débrief : pas de séparation technique claire "interne" vs "partageable" ; le mécanisme de récap partageable semble non branché.
- Relances : idempotentes côté followups automatiques, pas côté tâches RDV ; gating plan 100% applicatif.
- Web vs mobile : pas de divergence de données sensibles trouvée ; le module Console owner est le principal point non conforme aux conventions du reste du produit.

N · OBSTACLES PAR PRIORITÉ

Audit international

Priorité	Obstacle	Preuve
1	Devise EUR hardcodée	catalog/index.tsx:43, orders/index.tsx, clients/[id]/orders.tsx, clés i18n contenant (€)
2	Normalisation téléphone France-only	MessageModal.handleWhatsApp — préfixe +33 supposé pour tout numéro à 10 chiffres commençant par 0
3	fr-FR hardcodé indépendamment de la langue active	MessageModal.tsx:51, orders/index.tsx:19, exportService.ts:119
4	Aucune préparation RTL	0 occurrence de l18nManager/writingDirection dans tout le repo — bloquant pour la Phase 4 (arabe)
5	Module Console owner non traduit	settings-owner.tsx, settings-support-access.tsx
6	Format de date DD/MM vs MM/DD	Correctement géré via dateFormat.ts selon la locale — pas un obstacle, bonne pratique déjà en place

O · RGPD

Audit sécurité et données sensibles

- medical_treatment, medical_notes, particularities, loyalty_notes : stockés en clair sur clients, protégés uniquement par RLS standard (auth.uid()=user_id).
- Exposition non maîtrisée dans les exports (exportService.ts, select(*) sans exclusion) — risque ÉLEVÉ.
- Listes/aperçus : bien filtrés (ClientListItem exclut explicitement les champs sensibles) — risque FAIBLE, bonne pratique confirmée.
- Données de démo : aucune valeur sensible insérée — risque FAIBLE.
- Rétention : archive réversible (archived_at) + suppression définitive immédiate coexistent, sans période de grâce — risque MOYEN, à documenter pour une politique RGPD formelle.
- Mobile/web : parité confirmée, pas de fuite différentielle par plateforme.
- RLS confirmé activé sur les 30 tables du schéma public (aucune oubliée) ; 4 tables sensibles (admin_audit_log, pilot_participants, security_login_events, user_roles) sont verrouillées par défaut (RLS activé, zéro policy), accessibles uniquement via des fonctions SECURITY DEFINER — bonne pratique confirmée.
- Découverte live : table google_calendar_tokens (tokens OAuth Google Calendar), protégée par une policy RLS standard mais non évaluée dans le volet RGPD initial — à ajouter au périmètre (durée de vie, rotation, révocation à la déconnexion du compte).

Trois options pour la V1 MLM (décision produit requise)

Option	Description
1	Retirer les champs de santé de la V1 MLM (le plus simple, perte de fonctionnalité existante pour les praticiens bien-être).
2	Conserver les colonnes, masquer l'UI par module/plan (compromis rapide).
3	Isoler ultérieurement dans une structure protégée dédiée (le plus robuste, le plus coûteux).

P · SANS CODE

Plan de correction recommandé

Phase	Objectif	Critère de sortie
P0 — Blocages techniques	Rotation immédiate du mot de passe migrate4.mjs ; réparer ou retirer proprement useCalendarSync* (la panne de sync native est désormais confirmée, plus seulement supposée).	Accès DB sécurisé confirmé ; sync native réparée ou retirée avec migration de nettoyage des colonnes appointments.native_event_id.
P1 — Stabilisation du modèle	Unifier les deux chemins de complétion de RDV ; ajouter garde anti-double-clic + idempotence sur la tâche objections.	Un seul chemin métier de complétion RDV, testé.
P2 — Services et hooks d'agrégation	Construire (ou confirmer l'inutilité de) une couche clientActivityService uniquement si les mesures de performance le justifient.	Décision documentée, pas de sur-ingénierie prématurée.
P3 — Refonte Contacts	Dépend de la décision produit sur status / contact_role / pipeline_stage et sur les champs V1 vs différés.	Décision produit validée avant développement.
P4 — Refonte Rendez-vous	Dépendance stricte : P0 et P1 résolus (sync calendrier, chemin de complétion unique).	P0 et P1 clos.
P5 — Mobile compagnon	Aucun blocage spécifique identifié au-delà de P1-P4 communs.	P1-P4 clos.
P6 — Nettoyage des colonnes historiques	journey_stage, AppointmentWithClient, ancien type Appointment, useStatusLabels.ts, referrals_count/referral_count, doublons de politiques RLS (followups/notes/recommendations).	Cartographie lecteurs/écrivains validée (déjà faite dans ce rapport).

Q · À TRANCHER AVANT DÉVELOPPEMENT

Décisions produit à faire valider

- 1. "Clients" ou "Contacts" comme terme produit V1 international.
- 2. Fusion ou séparation formelle de status / contact_role / pipeline_stage (aujourd'hui 3 axes qui se chevauchent partiellement : prospect, team_member, inactive, lost).
- 3. Faut-il retirer "advisor"/"leader" du vocabulaire des plans d'abonnement pour lever l'ambiguïté avec les rôles MLM, ou l'inverse ? (le code confirme que l'équipe a déjà identifié ce chevauchement comme "legacy")
- 4. Place de "VIP" : statut de cycle de vie ou segment de fidélité distinct (aujourd'hui non relié à loyalty_notes/next_lrp_date) ?
- 5. Faut-il unifier le comportement "compléter un RDV" entre la fiche RDV et le dossier client (aujourd'hui divergent) ?
- 6. Faut-il garder les données de santé (medical_treatment/medical_notes/particularities) dans la V1 MLM, et sous quelle protection à l'export ?
- 7. Faut-il exposer team_member/lost dans les formulaires UI (aujourd'hui accessibles seulement via import/API) ?
- 8. Rôle exact des tâches post-RDV : le système appointment_tasks est en réalité généralisé (11 types) — faut-il l'exposer plus largement dans l'UI au-delà du seul suivi des objections ?
- 9. Faut-il réparer ou retirer la synchronisation agenda natif (désormais confirmée cassée en production) ?
- 10. Périmètre exact du "mobile compagnon" V1 (lecture seule sur quels objets, actions rapides sur lesquels ?).

R · LIMITES DE L'AUDIT

Informations encore manquantes

- Historique du schéma clients/profiles antérieur à migrate4.mjs : scripts migrate.mjs/migrate2.mjs/migrate3.mjs supprimés du dépôt — origine exacte de plusieurs colonnes non reconstituable, même avec l'accès live (elle précède l'état actuel du schéma).
- Détail champ par champ de la création de contact : cet audit a couvert les principaux champs (statut, rôle, pipeline, réseau) mais pas une revue exhaustive de chaque champ RGPD/optionnel de new.tsx/edit.tsx.
- Contenu détaillé de appointment_notes, appointment_attendees : existence confirmée par les migrations et l'introspection live, structure et usages applicatifs non audités en profondeur (appointment_tasks a en revanche été précisé via les enums task_type/task_status/task_priority).
- Définition complète de has_advisor_access, is_app_owner, sync_client_pipeline_from_appointment/followup, et des fonctions owner_* : listées par l'introspection live mais leur code source complet n'a pas été communiqué (réponse tronquée à 50 000 caractères) — comportement resté au statut déduit des migrations, non contredit par ce qui a été vérifié.
- Politique de rotation/expiration des tokens dans google_calendar_tokens (table découverte en live, non auditée en profondeur).

S · RÉPONSES AUX 10 QUESTIONS

Verdict final

Question	Réponse
1. Refonte visuelle immédiate ?	Possible sur les écrans de lecture pure (dashboard, listes, agenda en consultation) — pas sur la fiche RDV ni le pipeline avant P0/P1.
2. Corrections obligatoires avant refonte ?	Rotation du secret DB ; réparation ou retrait de la sync calendrier native (panne désormais confirmée) ; unification des deux chemins de complétion de RDV.
3. Conserver la DB actuelle en 1ère étape ?	Oui, aucune migration structurelle requise pour une refonte UI des écrans de lecture.
4. Migration avant nouvelle fiche Contact ?	Non indispensable techniquement, mais une décision produit sur status/contact_role/pipeline_stage devrait précéder.
5. Migration avant nouvelle fiche RDV ?	Oui — la sync calendrier native étant confirmée cassée, une migration de nettoyage (colonnes appointments.native_event_id et alentours) est nécessaire avant de redessiner cet écran.
6. Écrans refaisables sans risque en premier ?	Dashboard (lecture), liste Contacts (lecture + filtres), agenda en consultation.
7. Plus gros risque de régression ?	La sync calendrier natif, confirmée cassée, si elle est touchée sans plan de réparation ou de retrait clair.
8. Plus gros risque UX ?	L'incohérence entre les deux chemins de complétion de RDV (résultat imprévisible pour l'utilisateur).
9. Plus gros risque de confidentialité ?	L'export complet non filtré des champs médicaux/sensibles.
10. Meilleur premier lot de développement ?	P0 (secret + réparation/retrait de la sync calendrier) suivi de P1 (unification du chemin de complétion RDV), avant tout travail visuel sur RDV/Contacts.

AUCUNE MODIFICATION EFFECTUÉE

Ce document synthétise un audit strictement en lecture seule, complété par une vérification live du schéma Supabase via des requêtes SQL exécutées par l'utilisateur lui-même. Aucune table, politique, colonne, contrainte, donnée ou fichier de code n'a été modifié par l'assistant. Validation produit attendue avant toute implémentation.